

1. IT Security Context – Why IT Security?

Today's systems are:

- Interconnected (wired / wireless, IP-based)
- Mobile (smartphones, laptops)
- Heterogeneous (different OS, protocols, technologies)

Reasons for IT Security:

- Data espionage
 - Data manipulation
 - Temporary malfunctioning (DoS, DDoS)
 - Permanent malfunctioning (fire, earthquake, etc.)
 - Monitoring of system usage (who / when)
 - Protection of information and information systems
-

2. What is IT Security?

Definition:

Protection of information and information systems against:

- Unauthorized access
- Unauthorized manipulation
- Impairment of availability

Includes **all actions** to:

- Prevent threats
- Detect threats
- Log threats

Protection must be ensured during:

- Storage
 - Processing
 - Transmission
-

3. IT Security Aims (Security Goals)

- **Confidentiality**
Protection against unauthorized access

- **Integrity**
Protection against unauthorized modification
 - **Availability**
Protection against unauthorized impairment of system functionality
 - **Authenticity**
Proof of authenticity and credibility of identity
 - **Accountability / Non-repudiation**
No inadmissible denial of performed actions
-

4. Causes of Security Issues

- **Bad Design**
 - Missing access control
 - Weak authentication
 - Weak passwords
 - **Implementation Errors**
 - Buffer overflow
 - Weak random number generator
 - **Administrative Errors**
 - Missing passwords
 - Too many open ports (firewall misconfiguration)
 - **Missing Awareness**
 - Social engineering
 - Poor security knowledge
-

5. Weakness, Vulnerability, Threat

- **Weakness**
A weak point in a system
- **Vulnerability**
A weakness that can be exploited to bypass or modify security services
- **Threat**
A potential cause of harm that exploits one or more vulnerabilities to violate security aims

➡ Threats **use vulnerabilities**, not weaknesses directly.

6. Hazard Factors (Threat Sources)

- **Acts of Nature**
 - Fire, flooding, lightning, earthquakes
 - **Negligence**
 - Fallacy
 - Maloperation
 - Inappropriate handling
 - **Technical Failure**
 - Blackout
 - Hardware failure
 - System malfunction
 - **Malice**
 - Manipulation
 - Burglary
 - Hacking
 - Vandalism
 - Spying
 - Sabotage
 - **Organizational Flaws**
 - Unauthorized access
 - Pirate copies
 - Untrained staff
-

7. Risk

- Vulnerabilities are not always exploited
- However, **risk always exists**

Risk consists of:

- Probability of occurrence
- Consequences (impact)

Risk handling options:

- Accept vulnerability (risk acceptance)
 - Eliminate vulnerability
 - Shut down the IT infrastructure
-

8. Attackers

- Inexperienced attackers
(e.g. script kiddies)
 - Skilled hackers
(limited budget, technical knowledge)
 - Criminal organizations / intelligence agencies
-

9. Attacks

Passive Attacks

- Attacker does not actively interfere
- Difficult to detect
- Examples:
 - Sniffing
 - Eavesdropping
 - Wiretapping

Active Attacks

- Attacker manipulates data or systems
- Often detectable

- Examples:
 - Data manipulation
 - System manipulation
 - DoS / DDoS
-

10. Social Engineering

Definition:

Attacks targeting **users**, not technical systems.

Goals:

- Information gathering (confidentiality)
- Inducing user actions (integrity)

Exploited human traits:

- Helpfulness
- Confidence
- Anxiety
- Respect for authority
- Curiosity
- Laziness
- Surprise
- Shame, guilt, anger, pride, envy, compassion

Categories:

- **Passive**
 - Shoulder surfing
 - Eavesdropping
 - Dumpster diving

- Baiting (USB sticks)
- **Active**
 - Pretexting
 - Phishing
 - Fake online friendships
- **Reverse Social Engineering**
 - Victim contacts attacker

Main types:

- Human-based social engineering
 - Computer-based social engineering
-

11. IT Security is a Process

IT security is **continuous** and adaptive.

Steps:

- Identify
- Set goals
- Implement
- Monitor
- Evaluate
- Modify

Mapped to **PDCA cycle**:

- Plan
- Do
- Check
- Act

12. Legal and Regulatory Context (Awareness Level)

- **GDPR**
Regulation of personal data processing
- **Telecommunications Law**
Secrecy of communications, lawful interception
- **Commercial Law**
Data retention and accessibility
- **Criminal Law**
Punishable cyber activities

Chapter 2a — CRYPTOGRAPHY

FULL SLIDE-FAITHFUL CHEAT SHEET (MCQ-SAFE)

1. Cryptography — Overview

Cryptography

- Encrypting and decrypting messages
- Besides **confidentiality**, cryptography can also provide:
 - **Integrity**
 - **Non-repudiation**
 - **Authentication**

Cryptology

- **Cryptology = Cryptography + Cryptoanalysis**
- **Cryptoanalysis = breaking cryptographic techniques**

2. Cryptography Model

Basic model

- Plaintext → Encryption → Ciphertext
- Ciphertext → Decryption → Plaintext

Components

- Encryption method
- Encryption key
- Decryption method
- Decryption key

⚠ MCQ trap:

- Security must **not** depend on secrecy of the algorithm
-

3. Kerckhoffs' Principle

Definition

Security should not depend on secrecy of the method.

Implications:

- Algorithms are assumed **public**
 - Only the **key** must remain secret
 - Modern cryptography strictly follows this principle
-

4. Steganography — Basics

Steganography

- Hiding a **secret message inside a non-secret message**
- Goal: hide **existence**, not content

Types

- **Linguistical steganography**
- **Technical steganography**

⚠ MCQ contrast:

- Cryptography → hides *content*
 - Steganography → hides *existence*
-

5. Linguistical Steganography

Semagrams

- Messages hidden in:
 - Images
 - Writings
- No obvious cipher text

Open Code

- Hidden message in harmless communication
Example:
 - coughing during *Who Wants to Be a Millionaire?*

Jargon Code

- Special words with agreed meaning
Examples:
 - “weed”, “snow”, “purple haze”

Cue

- Phrase with predefined meaning
Example:
 - *HIGASHI NO KAZE AME* repeated twice → “war with USA”

Concealment Ciphers

- **Null cipher:** letters hidden at specific positions
 - **Grille cipher:** message revealed using a mask
-
-

7. Technical Steganography

Methods

- Invisible ink
- Microdots
- Shaved heads
- Image steganography

Image Steganography

- Use of **Least Significant Bits (LSB)**
- Message encoded in **redundant bits**
- Causes **very small changes** in image

Binary example:

- RGB values slightly altered
 - Visual appearance mostly unchanged
-

8. Image Modifications & Histogram

Key idea

- Steganography introduces **statistical anomalies**

Histogram comparison:

- Original image vs steganographic image

- Slight shifts in:
 - Mean
 - Median
 - Distribution

⚠ MCQ:

- Steganography is *detectable* via statistical analysis
-

9. Encryption Methods (Classical)

Substitution Cipher

- Replace symbols with other symbols
- Order preserved

Transposition Cipher

- Rearrange symbols
- Symbols unchanged

Product Cipher

- Combination of substitution + transposition
 - Basis of modern cryptography (bits & bytes)
-

10. Substitution Cipher — Caesar Cipher

Properties

- Alphabet shift by fixed value n
- Example:
 - $n = 7$

- Plaintext: KNOWLEDGE IS POWER
- Ciphertext: RUVDSLKNL PZ WVDLY

⚠ Weakness:

- Small key space
 - Easily brute-forced
-

11. Transposition Cipher — Scytale

Properties

- Letters reordered
- Original letters preserved
- Ancient Greek cipher

Example

- Plaintext: KNOWLEDGE IS POWER
- Ciphertext: DKELNOWG EEWOISPR

Key idea:

- Encryption by **position**, not substitution
-

12. Cryptoanalysis — General

Key Space

- Number of possible keys
- Larger key space → harder to break

Attack Types

- **Ciphertext-Only Attack**
- **Known-Plaintext Attack**
- **Chosen-Plaintext Attack**
- **Chosen-Ciphertext Attack**



MCQ favorite:

Chosen-ciphertext is the **strongest attacker model**

13. Brute Force Attack

Definition

- Try all possible keys until correct one found

Assumption

- Finite key space
- Example: 1 million keys/second

Time vs Key Size

- 16-bit → seconds
- 32-bit → minutes
- 64-bit → hundreds of thousands of years
- 128-bit → astronomically large
- 256-bit → practically impossible

Key formula:

- $\text{Time} \propto 2^n$
-

14. Security of Encryption Schemes

Key Insight

- Long keys alone are not sufficient

Example:

- Monoalphabetic substitution
 - Key space = $26!$
 - Still breakable via statistics
-

15. Statistical Analysis

Letter Frequency (English)

- $E \approx 12.7\%$
- $T \approx 9.1\%$
- $A \approx 8.2\%$
- Q, Z $\approx$ very low

Attack Method

- Compare ciphertext frequency
- Map peaks to common letters
- Break substitution cipher



MCQ:

- Works because language is **non-random**
-

16. Structural Weaknesses in Ciphertext

Problems revealed:

- No spaces
- No punctuation

- Repeated patterns

Reconstruction possible even without key.

17. One-Time Pad (OTP)

Properties

- **Perfectly secure** if used correctly

Requirements

- Key as long as plaintext (minimum)
- Truly random
- Never reused

Operation

- XOR plaintext with key

Limitations

- Key generation is expensive
- Key distribution must be secure
- Not practical at scale

⚠ MCQ classic:

- Reusing OTP key → **catastrophic failure**

CHAPTER 2b — FULL SLIDE-COVERAGE CHEAT SHEET

(Ordered exactly as the slides)

SLIDE 1 — Cryptographical Methods

- Two cryptographic methods:
 - Symmetrical method (Secret-Key)
 - Asymmetrical method (Public-Key)

Encryption model

- Encryption key e
- Decryption key d

Key relation

- Symmetric:
 - $e = d$
 - Key must be secret
 - Examples: DES, AES
- Asymmetric:
 - $e \neq d$
 - Public key / Private key
 - Examples: RSA, ElGamal

SLIDE 2 — Symmetric Cipher Model

- Plaintext block size: m
- Key size: n
- Ciphertext block size: m

Properties

- Plaintext $\rightarrow$ Ciphertext using key
- Ciphertext $\rightarrow$ Plaintext using same key

Algorithms

- DES
 - Block size: 64 bit
 - Key size: 56 bit
 - AES
 - Easily implemented in hardware
-

SLIDE 3 — Symmetric Encryption Schemes

Method	DES	3-DES	AES-128	AES-192	AES-256
Key length	56	112	128	192	256
Block size	64	64	128	128	128

SLIDE 4 — Stream Cipher

- Initial value = key
 - Generates pseudo-random keystream
 - Keystream length = plaintext length
 - Encryption:
 - Plaintext XOR keystream → Ciphertext
 - Decryption:
 - Ciphertext XOR keystream → Plaintext
-

SLIDE 5 — Block Cipher

- Plaintext split into fixed-length blocks
 - Encrypt block by block
 - Same key used for every block
 - Encryption and decryption done per block
-

SLIDE 6 — Block Cipher Modes: ECB

- ECB (Electronic Code Book)
- Block-by-block encryption
- Same plaintext block → same ciphertext block

Problems

- Reload blocks
- Change order of blocks
- Remove blocks

SLIDE 7 — Block Cipher Modes: CBC

- CBC (Cipher Block Chaining)
- Plaintext block is combined with previous ciphertext block
- Uses Initialization Vector (IV) for first block
- Same plaintext blocks → different ciphertext blocks

SLIDE 8 — Further Cipher Modes: OFB & CFB

- OFB (Output Feedback)
- CFB (Cipher Feedback)
- Both use block cipher as stream cipher
- OFB:

- Generates keystream blocks
- Keystream XOR plaintext → ciphertext

SLIDE 9 — Further Cipher Modes: CTR

- CTR (Counter) mode
 - Example: AES
 - Uses:
 - Nonce + Counter
 - Counter increments for each block
 - Same process for encryption and decryption
 - XOR operation used
-

SLIDE 10 — Asymmetric Encryption

- Uses key pair
 - Public key
 - Private key
- Based on one-way functions

Process

- Encryption: recipient's public key
 - Decryption: recipient's private key
-

SLIDE 11 — Public-Key Methods

- Message encrypted with public key
- Only decryptable with private key

- Public key knowledge $\neq$ private key knowledge
- Public key can be distributed over insecure channels
- Keys are much longer than symmetric keys

Mathematical basis

- Diffie-Hellman $\rightarrow$ discrete logarithm
- ElGamal $\rightarrow$ elliptic curves
- RSA $\rightarrow$ product of prime numbers

SLIDE 12 — Example: RSA

- Developed by Rivest, Shamir, Adleman

RSA key generation steps

1. Choose two distinct primes p, q
2. Compute $n = p \times q$ (modulus)
3. Compute $\phi(n) = (p-1)(q-1)$
4. Choose e
 - $1 < e < \phi(n)$
 - $\gcd(e, \phi(n)) = 1$
5. Compute d
 - $d = e^{-1} \bmod \phi(n)$
 - d is modular multiplicative inverse

SLIDE 13 — Symmetric vs Asymmetric Comparison

Aspect	Symmetric	Asymmetric
--------	-----------	------------

Key exchange	Secure channel needed	Public key
Key length	128 / 256 bit	2048 – 8192 bit
Performance	Fast	100–1000× slower
Implementation	Easy (HW/SW)	Computationally expensive

SLIDE 14 — Hybrid Methods

- Use asymmetric encryption to exchange session key
 - Then use symmetric encryption
 - Combines:
 - Secure key exchange
 - High performance
-

SLIDE 15 — Hash Functions

- Purpose: proof of integrity
 - Unique hash values for data
 - One-way
 - Not injective → collisions possible
 - Any data change → hash changes
 - Example: software distribution
-

SLIDE 16 — Example Hash Function (MD5)

- MD5
 - Output length: 128 bits
 - Fixed length, independent of input size
 - Total possible hashes: 2^{128}
 - Collisions exist
 - Small input change → different hash (collision resistance goal)
-

SLIDE 17 — Hash Function Construction

- Based on compression function
 - Message split into blocks M_i
 - Fixed block length y
 - Uses initial vector (IV)
 - Last block padded if necessary
 - Output: hash value
-

SLIDE 18 — Message Authentication Code (MAC)

- Provides:
 - Integrity
 - Authenticity of source
- Uses:
 - Hash function
 - Pre-shared key
- Types:
 - CBC-MAC

- HMAC
- Sender and receiver share key

Chapter 3 — Blockchain

FULL CHEAT SHEET (Slide-Complete, MCQ-Safe)

1. Blockchain Basics

- Introduced for **cryptocurrency Bitcoin**
- **Distributed database** that records:
 - Transactions
 - Agreements
 - Contracts
 - Digital assets
- **Several transactions per block**
- **Blocks linked in a chain**
- Each block contains **hash of predecessor**
- Every participant has an **identical copy of the ledger**
- Any ledger change is **reflected in all copies**
- **Security & accuracy ensured cryptographically**

Advantages of Blockchain

- **Decentralization**
 - **Transparency**
 - **Immutability**
 - **Redundancy**
-

2. Blockchain Structure (Block Anatomy)

Each block consists of:

Block Header

- Version
- Previous Block Header Hash
- Timestamp
- Difficulty Target
- Nonce
- Merkle Root

Block Body

- Transactions

Blocks are chained via **previous hash reference**

3. Blockchain Applications

- Smart Contracts
- Cryptocurrencies
- Electronic Auctions
- Supply Chain
- Identity Management
- Diamond Trade
- Internet of Things (IoT)
- Government (border control, voting, ID cards)
- Health
- Media
- Finance

4. Blockchain Types

Open Blockchain

- Public
- Permissionless
- Anyone can participate

Closed Blockchain

- Private (permissioned)
- Consortium

Hybrid Blockchain

- Combines **public + private** benefits
-

5. Key Elements of Blockchain

Five fundamental elements:

1. **Cryptography**
 2. **Peer-to-Peer (P2P) Network**
 3. **Validity Rules**
 4. **Consensus Mechanism**
 5. **Ledger**
-

6. Blockchain Workflow (Bitcoin)

High-level flow:

1. Transaction is created

2. Transaction syntax + inputs/outputs checked
 3. Transaction broadcast to peers
 4. Stored in **non-persistent memory**
 5. Selected for block inclusion
 6. Miner creates block header
 7. Mining starts (nonce iteration)
 8. Hash $\leq$ target threshold $\rightarrow$ success
 9. Block broadcast to network
 10. Peers validate block
 11. Block added to blockchain
 12. Transaction becomes confirmed
-

7. Blockchain Workflow – New Node

A new node:

- Is a device connected to the internet
- Maintains the blockchain

Requirements

- **Private/Public key pair**
- **Public address**
- Connection to existing blockchain nodes

Wallet Programs Functions

- Create private keys
- Derive public keys
- Distribute public keys
- Interact with P2P network

- Monitor outputs
 - Create transactions
 - Sign transactions
 - Broadcast transactions
-

8. New Node – Public Address Generation

Steps:

1. Generate **random 256-bit private key**
 2. Apply **Elliptic Curve Cryptography** → public key
 3. Perform **SHA-256 hash**
 4. Perform **RIPEMD-160 hash**
 5. Perform **Base58Check encoding**
 6. Result = **Public Address**
-

9. Transactions

- Represents **transfer of value** between addresses
- Transaction data may include:
 - Account balances
 - Certificates
 - Sensor data
 - Industry data
 - Source code
 - Digital attributes

Bitcoin Transaction Structure

- Transaction ID

- Metadata
 - Inputs
 - Outputs
 - Each input references an **output of a previous transaction**
 - Outputs are tied to **hashes of signed transactions**
-

10. Merkle Tree

- Transactions inside a block stored in a **Merkle Tree**
 - Used to verify transaction inclusion efficiently
 - Only **Merkle root + sibling hashes** needed for verification
 - Reduces data needed for validation
-

11. Transaction Storage & Status

Transaction states:

- Created
- Broadcast
- Verified
- Stored in memory pool
- Included in block
- Confirmed after block acceptance

Unconfirmed transactions may be removed if:

- Memory is full
 - Fee threshold too low
-

12. Block Creation & Mining

- Transactions collected from local memory
 - Block header created
 - Miner iterates **nonce**
 - Hash compared to **difficulty target**
 - Successful hash → block created
 - Block broadcast to peers
-

13. Consensus

Purpose:

- Ensure **same ledger copy** across nodes

Goals:

- Avoid information conflicts
- Prevent **Sybil attacks**
- Incentivize miners

Consensus Mechanisms

- Proof of Work (PoW)
 - Proof of Stake (PoS)
 - Delegated Proof of Stake (DPoS)
 - Nano
 - Ripple
 - Tangle
-

14. Block Validation

Peers verify:

- Index increment
- Previous hash match
- Block hash validity
- Transaction validity

Invalid blocks → rejected

Valid blocks → added to blockchain

15. Current Blockchain State

- Multiple versions may exist temporarily
 - Network follows:
 - **Longest**
 - **Most difficult** chain
-

16. Forks in the Blockchain

- **General fork**
 - In Bitcoin:
 - **Soft Fork** (backward compatible)
 - **Hard Fork** (not backward compatible)
-

17. Sending a Transaction (Example)

- Transaction created by sender
- Broadcast to blockchain nodes
- Verified independently
- Forwarded to next nodes

18. Creating a Block (Example)

- Node collects transactions
- Builds block
- Broadcasts candidate block

19. Block Mining (Consensus – Example)

- Miner iterates nonce
- Hash must be $\leq$ target threshold
- First miner succeeds
- Block broadcast

20. Block Acceptance (Example)

- Nodes verify received block
- Blockchain updated
- Block forwarded to peers

21. Smart Contracts

- **Self-enforcing software**
- Managed by P2P network
- No traditional legal contracts needed
- Execute instructions automatically
- Can:

- Calculate
- Store data
- Send transactions

Examples:

- Replace brokers (Amazon, Ebay, Airbnb)
 - Analogy: **vending machine**
 - Ethereum enables smart contracts
-

22. Smart Contracts Workflow

1. Transaction requests smart contract
 2. Contract deployed
 3. Mining nodes execute contract
 4. Events triggered
 5. Results returned
 6. Block mined with results
 7. Confirmation sent
-

23. Blockchain Issues & Limitations

Security issues:

- Integrity vs Confidentiality
- Non-repudiation
- Identity of physical assets
- **51% attack**

Critical questions (EXAM FAVOURITES):

- Is blockchain data always correct?
- Is everything decentralized?
- Is data stored forever?
- Does blockchain ensure anonymity?

→ Answer: NOT always true

Chapter 4 — AUTHENTICATION

FULL SLIDE COVERAGE CHEAT SHEET (WITH IMAGE/DIAGRAM FLAGS)

Slide 1 — Authentication

Authentication

- Clear identification **and** proof of identity
- Defense against **spoofing attacks**

Authentication of:

- **Users** (person, process, instance, ...)
- **Devices** (server, laptop, mobile, ...)
- **Services** (filesystem, banking portal, ...)
- **Messages** (e-mails, ...)

 MCQ trap: authentication is **not limited to users only**

Slide 2 — Classes of Authentication

Authentication by Knowledge

- Password
- PIN
- Cryptographic key
- TAN

Authentication by Possession

- Smartcard
- USB token
- SIM card (mobile phone)

Authentication by Biometric characteristics

- Fingerprint
- Iris
- Size
- DNA (deoxyribonucleic acid)

Authentication by Behavior-based biometrics

- Voice recognition
- Way of walking (gait)

Multi-factor authentication

- Combination of **different authentication classes**

- Example: banking card + PIN

Definitions:

- PIN = Personal Identification Number
- TAN = Transaction Authentication Number
- SIM = Subscriber Identification Module

⚠ MCQ trap: two passwords $\neq$ multi-factor authentication

Slide 3 — Password Security

Password security depends on:

- Size of **password domain**
- Choice of password & password policies
- Security of **storing passwords**
- Security when **entering / transmitting** passwords

Password domain size

- Determined by:
 - Number of possible characters (**q**)
 - Password length (**n**)
- Entropy expressed as **bit equivalent**
- Formula shown:
 $\log_2(q^n)$

Examples on slide:

- Digits only (0–9)
- a–z
- a–z, A–Z, 0–9
- With additional characters
- Length 8 vs length 16 → **exponential increase**

⚠ MCQ trap: length increases security more than “special characters”

Slide 4 — Challenge–Response Authentication

 see image/diagram on slide

- Both sides know:
 - The **hash function**
 - The **secret**

Process:

1. User generates random value **x**
2. System computes response using **H()**
3. System compares response **y** with stored or computed value

Purpose:

- Secret is **never transmitted directly**
-

Slide 5 — Authentication by Symmetric Key

 see image/diagram on slide

Process:

- User A generates random x
- User B compares y with own computation

Assumption:

- **Shared secret key already exchanged**
- Based on symmetric encryption

 MCQ trap: symmetric authentication requires prior secure key exchange

Slide 6 — Authentication by Public Key

 see image/diagram on slide

Process:

- User A generates random x
- User B verifies y using **A's public key**

Assumption:

- User B knows A's public key

Difference vs symmetric:

- No shared secret
-

Slide 7 — Public-Key Authentication (Advantages & Alternative)

Advantages

- No secret agreement in advance
- Client & server do not share secrets

Critical requirements

- Public keys **must be authentic**
- **Public Key Infrastructure (PKI) is necessary**
- Server must protect stored public keys from replacement attacks

Alternative

- Server requests a **valid certificate** at each login
- Certificate validity used to verify public/private key pair

⚠ MCQ trap: public-key crypto alone does **not** guarantee trust

Slide 8 — Digital Signature

 see image/diagram on slide

Signing

1. Data → hash function
2. Hash encrypted with **private key**
3. Result = **digital signature**

Verification

1. Signature decrypted with **public key**

2. Hash recomputed from data
3. Hash values compared

Provides:

- Integrity
 - Authenticity
 - Non-repudiation
-

Slide 9 — Creation of Trust

 see image/diagram on slide

Trust models:

- **Direct Trust**
- **Web of Trust**
- **Hierarchical Trust**

Public key trust:

- Public key certified by **Certification Authority (CA)**

 MCQ trap: PKI is based on **hierarchical trust**

Slide 10 — Public Key Infrastructure (PKI): Components

Certification Authority (CA)

- Issues certificates

- Signs certificates
- Publishes certificates
- Creates & publishes **CRLs**
- Provides **OCSP**

Registration Authority (RA)

- Guarantees link between:
 - Public key
 - Identity of certificate holder

Directory Service

- Example: **LDAP**
 - Distribution of certificates and CRLs
-

Slide 11 — PKI: Additional Functions

Timestamp

- Signed timestamp
- Used for validity periods

Personalization

- Transmission of:
 - Secret keys
 - Certificates

Slide 12 — Certificates

Certificates:

- Bind **public key to its owner**
- Digitally signed by a **CA**
- Standard: **ITU X.509**

Example fields:

- Subject name
- Issuer name
- Serial number
- Validity (NotBefore / NotAfter)
- Subject key (e.g. sha256RSA)

Slide 13 — X.509 Version 3 Format

 see image/diagram on slide

Fields include:

- Version
- Serial number
- Signature algorithm identifier
- Issuer name
- Validity period

- Subject name
- Subject public-key info
- Issuer unique ID
- Subject unique ID
- Extensions
- Signature (encrypted)

⚠ MCQ trap: X.509 v3 explicitly supports **extensions**

Slide 14 — Certificate Hierarchies

 see image/diagram on slide

- Higher-level CAs issue certificates to lower CAs
- Everyone trusts the **Root CA**
- Certificate validation via **certification path**

Hierarchy shown:

- Root CA
 - Intermediate CAs
 - End-entity (user) certificate
-

Slide 15 — Biometrics

Dynamic traits

- Signatures
- Voice
- Keystroke
- Gait

Static traits

- Fingerprint
- Hand geometry
- Iris

Slide 16 — Biometric Authentication: Requirements

Requirements:

- **Universality**
- **Uniqueness**
- **Permanence**
- **Measurability**
- **Performance**
- **Acceptability**
- **Circumvention**

 MCQ classic: wording appears **verbatim** in options

Slide 17 — Biometric Authentication: Procedure

 see image/diagram on slide

Steps:

1. Feature extraction & data acquisition
2. Enrolment (store reference data, e.g. 5–7 samples)
3. Capture verification data
4. Digitization & normalization
5. Comparison using **tolerance thresholds**

 MCQ trap: biometric matching is **threshold-based**, not exact

Final Status Check

- ✓ Full slide coverage
- ✓ No skipped bullets
- ✓ All images/diagrams explicitly flagged
- ✓ MCQ-optimized wording
- ✓ Rule applied consistently

When ready, say:

- “**Chapter 5 go**”, or
- “**Give me MCQ traps from Chapter 4 only**”, or
- “**Merge Chapter 3 + 4 into one mega cheat sheet**”

You’re doing this the *right* way.

CHEAT SHEET — Chapter 5 (UPDATED, SAME FORMAT)

Malware

- Malicious software intended to harm systems
-

Distribution-based classification

- Virus → needs host, user action
 - Worm → *self-replicating, no host, network-based* ← (Slide 4 added)
 - Trojan → *disguised as useful software, no replication* ← (Slide 5 added)
-

Virus types

- Parasitic → executable infection
 - Memory-resident → RAM-based
 - Boot sector → MBR infection
 - Stealth → hides from AV
 - Polymorphic → changing signature
 - Metamorphic → full rewrite
 - Retrovirus → attacks antivirus
 - Macro virus → document-based, email spread
-

Worms (*Slide 4 — explicit*)

- No host program required
- Self-replicating
- Typically spreads over networks

- Uses user privileges or system vulnerabilities
 - Major risk due to permanently connected systems
-

Trojan Horse (*Slide 5 — explicit*)

- Program with hidden side-effects
 - Appears useful or attractive (game, software update)
 - Executes additional hidden tasks
 - Often installs virus, worm, or backdoor
 - Can directly destroy data
 - Does not self-replicate
-

Damage-based classification

- Spyware → secret data collection
 - Adware → unwanted ads
 - Ransomware → encrypts data
 - Zombie → botnet member
 - Backdoor → bypass security
 - Rootkit → hides attacker presence
-

Damage caused

- Data theft
 - Usability impairment
 - Resource abuse
 - Financial cost
-

Dissemination matrix

- **Virus → user action + self-replicating**
 - **Worm → no user action + self-replicating**
 - **Trojan/Spyware/Adware → user action + non-self-replicating**
-

Safeguards

- **Patch systems**
- **Disable unused services**
- **Antivirus**
- **Firewalls**
- **User awareness**